

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM



TRẦN ĐÌNH KHIÊM	1871020334
LA VĂN HẢI	1871020215
LƯƠNG NHƯ Ý	1871020680
TRƯƠNG VĂN BAN	1871020070

SECURE CHAT SYSTEM WITH CRYPTOGRAPHIC SECURITY

BÁO CÁO THỰC TẬP TỐT NGHIỆP NGÀNH

HÀ NỘI, NĂM 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM



TRẦN ĐÌNH KHIÊM

MSV: 1871020334, KHÓA: K18

SECURE CHAT SYSTEM WITH CRYPTOGRAPHIC SECURITY

BÁO CÁO THỰC TẬP TỐT NGHIỆP

NGÀNH: CÔNG NGHỆ THÔNG TIN

CHUYÊN NGÀNH: CÔNG NGHỆ PHẦN MỀM

GIẢNG VIÊN HƯỚNG DẪN: ThS. Lê Thị Thùy Trang

HÀ NỘI, NĂM 2026

LỜI CAM ĐOAN

Tôi xin cam đoan báo cáo thực tập tốt nghiệp với đề tài **SECURE CHAT SYSTEM WITH CRYPTOGRAPHIC SECURITY** là kết quả nghiên cứu, tìm hiểu và thực hiện của cá nhân tôi trong suốt quá trình thực tập và thực hiện đề tài.

Các nội dung, số liệu, hình ảnh và kết quả trình bày trong báo cáo là trung thực, được thu thập từ quá trình nghiên cứu, thực nghiệm và có trích dẫn nguồn đầy đủ đối với các tài liệu tham khảo. Tôi hoàn toàn chịu trách nhiệm trước Nhà trường về tính chính xác, trung thực và khách quan của toàn bộ nội dung trong báo cáo này.

Nếu có bất kỳ sự sao chép hoặc vi phạm bản quyền nào, tôi xin hoàn toàn chịu trách nhiệm theo quy định của Nhà trường.

Hà Nội, ngày ... tháng ... năm 2026

Sinh viên thực hiện

TRẦN ĐÌNH KHIÊM

LỜI CẢM ƠN

Trong suốt quá trình học tập tại Trường Đại học Đại Nam và thực hiện học phần thực tập tốt nghiệp, em đã nhận được rất nhiều sự quan tâm, hướng dẫn và giúp đỡ quý báu từ quý thầy cô, đơn vị thực tập cùng gia đình và bạn bè.

Trước hết, em xin bày tỏ lòng biết ơn sâu sắc tới Ban Giám hiệu Trường Đại học Đại Nam, Ban Chủ nhiệm Khoa Công nghệ thông tin cùng toàn thể quý thầy cô đã tận tình giảng dạy, truyền đạt kiến thức và tạo điều kiện thuận lợi cho em trong suốt quá trình học tập.

Đặc biệt, em xin gửi lời cảm ơn chân thành tới **ThS. Lê Thị Thùy Trang**, người đã trực tiếp hướng dẫn, tận tình góp ý, định hướng và hỗ trợ em trong suốt quá trình thực hiện đề tài cũng như hoàn thiện báo cáo thực tập tốt nghiệp.

Em xin chân thành cảm ơn đơn vị thực tập cùng các anh/chị hướng dẫn tại doanh nghiệp đã tạo điều kiện để em được tiếp cận môi trường làm việc thực tế, tham gia vào các công việc chuyên môn, đồng thời chia sẻ nhiều kinh nghiệm quý báu giúp em nâng cao kiến thức và kỹ năng nghề nghiệp.

Mặc dù đã rất cố gắng trong quá trình thực hiện, nhưng do thời gian, kiến thức và kinh nghiệm thực tế còn hạn chế nên báo cáo không tránh khỏi những thiếu sót. Em rất mong nhận được những ý kiến đóng góp của quý thầy cô để báo cáo được hoàn thiện hơn.

Em xin chân thành cảm ơn!

Hà Nội, ngày ... tháng ... năm 2026

Sinh viên thực hiện

TRẦN ĐÌNH KHIÊM

KÝ HIỆU CÁC CỤM TỪ VIẾT TẮT

Bảng 0.1. Danh mục các cụm từ viết tắt

Từ viết tắt	Ý nghĩa
AES	Advanced Encryption Standard
AES-GCM	Advanced Encryption Standard - Galois/Counter Mode
API	Application Programming Interface
CSS	Cascading Style Sheets
HTML	HyperText Markup Language
HTTP	HyperText Transfer Protocol
RSA	Rivest–Shamir–Adleman
RSA-OAEP	RSA Optimal Asymmetric Encryption Padding
RSA-PSS	RSA Probabilistic Signature Scheme
UI	User Interface
URL	Uniform Resource Locator
UUID	Universally Unique Identifier

DANH MỤC CÁC BẢNG, SƠ ĐỒ, HÌNH

BẢNG:

Tên bảng	Trang
Bảng 0.1. Danh mục các cụm từ viết tắt	iii
Bảng 2.1. Quá trình thực hiện đề tài	11
Bảng 3.1. Danh sách công nghệ sử dụng	13

SƠ ĐỒ:

Tên sơ đồ	Trang

HÌNH:

Tên hình	Trang
Hình 2.1. Mô phỏng tấn công Modify Ciphertext.....	6
Hình 2.2. Mô phỏng Replay Attack	7
Hình 2.3. Mô phỏng sử dụng Session Key không hợp lệ	7
Hình 2.4. Mô phỏng tấn công Fake Sender	8
Hình 2.5. Mô phỏng tấn công Modify Sequence Number	9
Hình .1. Giao diện đăng ký tài khoản	17
Hình .2. Giao diện đăng nhập	18
Hình .3. Giao diện nhắn tin thời gian thực	18
Hình .4. Giao diện Security Information.....	19
Hình .5. Tiếp tục giao diện Security Information	20

MỤC LỤC

LỜI CAM ĐOAN	i
LỜI CẢM ƠN	ii
KÝ HIỆU CÁC CỤM TỪ VIẾT TẮT	iii
DANH MỤC CÁC BẢNG, SƠ ĐỒ, HÌNH	iv
LỜI MỞ ĐẦU	vii
CHƯƠNG 1. CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG	1
1.1. Giới thiệu đề tài	1
1.2. Tổng quan về hệ thống nhắn tin bảo mật	1
1.3. Các công nghệ sử dụng	2
1.3.1. <i>Python</i>	2
1.3.2. <i>Flask</i>	2
1.3.3. <i>Flask-SocketIO</i>	2
1.3.4. <i>HTML, CSS và JavaScript</i>	2
1.3.5. <i>Git và GitHub</i>	2
1.4. Các thuật toán mật mã được sử dụng	3
1.4.1. <i>RSA</i>	3
1.4.2. <i>RSA-OAEP</i>	3
1.4.3. <i>AES-GCM</i>	3
1.4.4. <i>RSA-PSS</i>	3
1.5. Các cơ chế bảo mật	3
1.5.1. <i>Session ID</i>	3
1.5.2. <i>Message ID</i>	4
1.5.3. <i>Sequence Number</i>	4
1.5.4. <i>Replay Detector</i>	4
1.5.5. <i>Session Key Rotation</i>	4
1.6. Kết luận chương	4
CHƯƠNG 2. NỘI DUNG THỰC HIỆN ĐỀ TÀI	5
2.1. Mô tả nội dung thực hiện	5
2.2. Các cuộc tấn công được mô phỏng	6
2.2.1. <i>Modify Ciphertext</i>	6
2.2.2. <i>Replay Attack</i>	6
2.2.3. <i>Wrong Session Key</i>	7

2.2.4. <i>Fake Sender</i>	8
2.2.5. <i>Modify Sequence Number</i>	8
2.3. Kiến trúc hệ thống và luồng xử lý dữ liệu	9
2.4. Các công việc đã thực hiện	10
2.5. Quy trình phát triển hệ thống	10
2.6. Chi tiết quá trình thực hiện	11
CHƯƠNG 3. KẾT QUẢ THỰC HIỆN ĐỀ TÀI	12
3.1. Tóm tắt nội dung đã thực hiện	12
3.2. Sản phẩm đã xây dựng	12
3.3. Kỹ năng đã rèn luyện được	14
3.3.1. <i>Kỹ năng chuyên môn</i>	14
3.3.2. <i>Kỹ năng mềm</i>	14
3.4. Đề xuất phát triển hệ thống	15
3.5. Đánh giá kết quả thực hiện	15
KẾT LUẬN	16
PHỤ LỤC	17
DANH MỤC TÀI LIỆU THAM KHẢO	22

LỜI MỞ ĐẦU

Trong những năm gần đây, cùng với sự phát triển mạnh mẽ của công nghệ thông tin và Internet, nhu cầu trao đổi thông tin trực tuyến ngày càng trở nên phổ biến. Tuy nhiên, bên cạnh sự thuận tiện đó, các nguy cơ về mất an toàn thông tin như nghe lén, giả mạo, sửa đổi dữ liệu hay tấn công phát lại cũng ngày càng gia tăng. Điều này đặt ra yêu cầu phải xây dựng các hệ thống truyền thông có khả năng bảo đảm tính bảo mật, tính toàn vẹn và tính xác thực của dữ liệu.

Xuất phát từ thực tế đó, trong quá trình thực tập tốt nghiệp, em đã nghiên cứu và thực hiện đề tài **SECURE CHAT SYSTEM WITH CRYPTOGRAPHIC SECURITY**. Đề tài tập trung xây dựng một hệ thống nhắn tin trực tuyến theo thời gian thực, đồng thời tích hợp các cơ chế bảo mật hiện đại như RSA-OAEP, AES-GCM, RSA-PSS, Replay Detection và Session Key Rotation nhằm nâng cao mức độ an toàn cho quá trình trao đổi dữ liệu giữa các người dùng.

Báo cáo trình bày toàn bộ quá trình nghiên cứu, thiết kế, xây dựng, triển khai và đánh giá hệ thống. Bên cạnh đó, báo cáo cũng mô tả các kỹ thuật bảo mật đã được áp dụng, kết quả kiểm thử và các tình huống mô phỏng tấn công nhằm đánh giá hiệu quả của hệ thống trong việc phát hiện và ngăn chặn các nguy cơ mất an toàn thông tin.

Thông qua quá trình thực hiện đề tài, em có cơ hội vận dụng những kiến thức đã học về lập trình Web, an toàn thông tin, mật mã học và phát triển phần mềm vào thực tế, đồng thời rèn luyện kỹ năng nghiên cứu, làm việc nhóm và giải quyết các vấn đề phát sinh trong quá trình phát triển hệ thống.

Chương 1

CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG

1.1 Giới thiệu đề tài

Trong những năm gần đây, sự phát triển mạnh mẽ của Internet và các nền tảng truyền thông trực tuyến đã làm gia tăng nhu cầu trao đổi thông tin giữa người dùng. Tuy nhiên, đi kèm với sự phát triển đó là nhiều nguy cơ mất an toàn thông tin như nghe lén dữ liệu, giả mạo người gửi, thay đổi nội dung thông điệp hay tấn công phát lại (Replay Attack). Vì vậy, việc xây dựng các hệ thống truyền thông có khả năng bảo vệ dữ liệu trong quá trình truyền tải là một yêu cầu rất quan trọng.

Đề tài **Secure Chat System with Cryptographic Security** được thực hiện nhằm xây dựng một hệ thống nhắn tin trực tuyến theo thời gian thực, đồng thời tích hợp các cơ chế bảo mật hiện đại để bảo đảm tính bí mật, tính toàn vẹn và tính xác thực của dữ liệu. Hệ thống không chỉ hỗ trợ trao đổi thông tin giữa các người dùng mà còn mô phỏng nhiều hình thức tấn công phổ biến trong lĩnh vực An toàn thông tin nhằm đánh giá hiệu quả của các cơ chế bảo mật đã triển khai.

1.2 Tổng quan về hệ thống nhắn tin bảo mật

Hệ thống nhắn tin bảo mật là ứng dụng cho phép nhiều người dùng trao đổi thông tin thông qua mạng Internet trong khi dữ liệu luôn được bảo vệ khỏi các nguy cơ bị đánh cắp hoặc chỉnh sửa.

Khác với các hệ thống nhắn tin thông thường chỉ tập trung vào chức năng truyền tải dữ liệu, hệ thống nhắn tin bảo mật còn phải đảm bảo các yêu cầu sau:

- Tính bí mật (Confidentiality): chỉ người gửi và người nhận mới có thể đọc được nội dung tin nhắn.
- Tính toàn vẹn (Integrity): dữ liệu không bị thay đổi trong quá trình truyền tải.
- Tính xác thực (Authentication): xác minh đúng danh tính người gửi.
- Khả năng chống phát lại (Replay Protection): ngăn chặn việc sử dụng lại các gói tin cũ.

Để đáp ứng các yêu cầu trên, hệ thống sử dụng kết hợp nhiều thuật toán mật mã hiện đại cùng các cơ chế quản lý phiên làm việc.

1.3 Các công nghệ sử dụng

Trong quá trình phát triển hệ thống, nhóm sử dụng nhiều công nghệ khác nhau nhằm đáp ứng yêu cầu về hiệu năng, khả năng mở rộng và tính bảo mật.

1.3.1 Python

Python là ngôn ngữ lập trình chính được sử dụng để xây dựng hệ thống. Python có cú pháp đơn giản, dễ phát triển và hỗ trợ nhiều thư viện phục vụ cho lập trình Web cũng như An toàn thông tin.

1.3.2 Flask

Flask là một Web Framework nhỏ gọn của Python, được sử dụng để xây dựng Web Server và xử lý các yêu cầu từ phía người dùng.

1.3.3 Flask-SocketIO

Flask-SocketIO cung cấp khả năng giao tiếp thời gian thực giữa Client và Server thông qua giao thức WebSocket. Nhờ đó hệ thống có thể gửi và nhận tin nhắn ngay lập tức mà không cần tải lại trang.

1.3.4 HTML, CSS và JavaScript

Ba công nghệ này được sử dụng để xây dựng giao diện người dùng, xử lý các thao tác trên trình duyệt và hiển thị kết quả một cách trực quan.

1.3.5 Git và GitHub

Git được sử dụng để quản lý phiên bản mã nguồn, trong khi GitHub hỗ trợ lưu trữ mã nguồn và làm việc nhóm.

1.4 Các thuật toán mật mã được sử dụng

1.4.1 RSA

RSA là thuật toán mật mã khóa công khai được sử dụng rộng rãi trong các hệ thống bảo mật. Thuật toán này sử dụng một cặp khóa gồm khóa công khai và khóa bí mật để thực hiện mã hóa hoặc ký số.

1.4.2 RSA-OAEP

RSA-OAEP được sử dụng để mã hóa khóa phiên AES trước khi truyền đến người nhận. Việc sử dụng OAEP giúp tăng cường khả năng chống lại các cuộc tấn công vào RSA truyền thống.

1.4.3 AES-GCM

AES-GCM là thuật toán mã hóa đối xứng được sử dụng để mã hóa nội dung tin nhắn. Ngoài việc đảm bảo tính bí mật của dữ liệu, AES-GCM còn sinh ra Authentication Tag giúp kiểm tra tính toàn vẹn của thông điệp.

1.4.4 RSA-PSS

RSA-PSS được sử dụng để tạo chữ ký số cho từng gói tin. Chữ ký số giúp người nhận xác minh đúng người gửi và phát hiện mọi thay đổi của dữ liệu trong quá trình truyền tải.

1.5 Các cơ chế bảo mật

Ngoài các thuật toán mật mã, hệ thống còn triển khai nhiều cơ chế bảo mật nhằm tăng khả năng chống tấn công.

1.5.1 Session ID

Mỗi phiên làm việc được gán một Session ID duy nhất để quản lý kết nối giữa hai người dùng.

1.5.2 Message ID

Mỗi tin nhắn được sinh ra một Message ID duy nhất nhằm phục vụ việc phát hiện các gói tin bị phát lại.

1.5.3 Sequence Number

Sequence Number tăng dần sau mỗi lần gửi tin nhắn. Khi phát hiện số thứ tự không hợp lệ, hệ thống sẽ từ chối xử lý gói tin.

1.5.4 Replay Detector

Replay Detector lưu trữ các Message ID đã xử lý. Nếu một Message ID xuất hiện nhiều lần, hệ thống sẽ xác định đây là Replay Attack.

1.5.5 Session Key Rotation

Sau một số lượng tin nhắn nhất định, hệ thống tự động sinh khóa phiên mới nhằm hạn chế nguy cơ lộ khóa nếu khóa phiên hiện tại bị đánh cắp.

1.6 Kết luận chương

Chương này đã trình bày các cơ sở lý thuyết và những công nghệ được sử dụng trong quá trình xây dựng hệ thống Secure Chat System with Cryptographic Security. Các kiến thức về lập trình Web, giao tiếp thời gian thực, mật mã học và các cơ chế bảo mật là nền tảng quan trọng để triển khai hệ thống được trình bày trong các chương tiếp theo.

Chương 2

NỘI DUNG THỰC HIỆN ĐỀ TÀI

Chương này trình bày quá trình nghiên cứu, thiết kế và xây dựng hệ thống Secure Chat System with Cryptographic Security. Nội dung bao gồm các công việc đã thực hiện, quy trình phát triển hệ thống, các cơ chế bảo mật được triển khai và kết quả đạt được trong từng giai đoạn thực hiện đề tài.

2.1 Mô tả nội dung thực hiện

Trong quá trình thực hiện đề tài, nhóm tiến hành nghiên cứu các kiến thức về mật mã học, an toàn thông tin và lập trình ứng dụng Web nhằm xây dựng một hệ thống nhắn tin có khả năng bảo mật dữ liệu trong quá trình truyền thông.

Đề tài được triển khai theo một quy trình gồm khảo sát yêu cầu, thiết kế kiến trúc, xây dựng module bảo mật, tích hợp giao diện người dùng và kiểm thử toàn diện. Mỗi giai đoạn đều được phân công rõ ràng để đảm bảo tiến độ và chất lượng sản phẩm. Việc đặt nền móng từ phân tích yêu cầu giúp nhóm xác định đúng các chức năng cần triển khai và ưu tiên các thành phần có tính bảo mật cao.

Đề tài được triển khai theo nhiều giai đoạn, từ khảo sát yêu cầu, thiết kế kiến trúc hệ thống, xây dựng giao diện người dùng, lập trình các chức năng chính, tích hợp các thuật toán mật mã cho đến kiểm thử và đánh giá toàn bộ hệ thống.

Các công nghệ và công cụ được sử dụng gồm:

- Python 3
- Flask
- Flask-SocketIO
- HTML, CSS và JavaScript
- Cryptography Library
- Git và GitHub
- Visual Studio Code

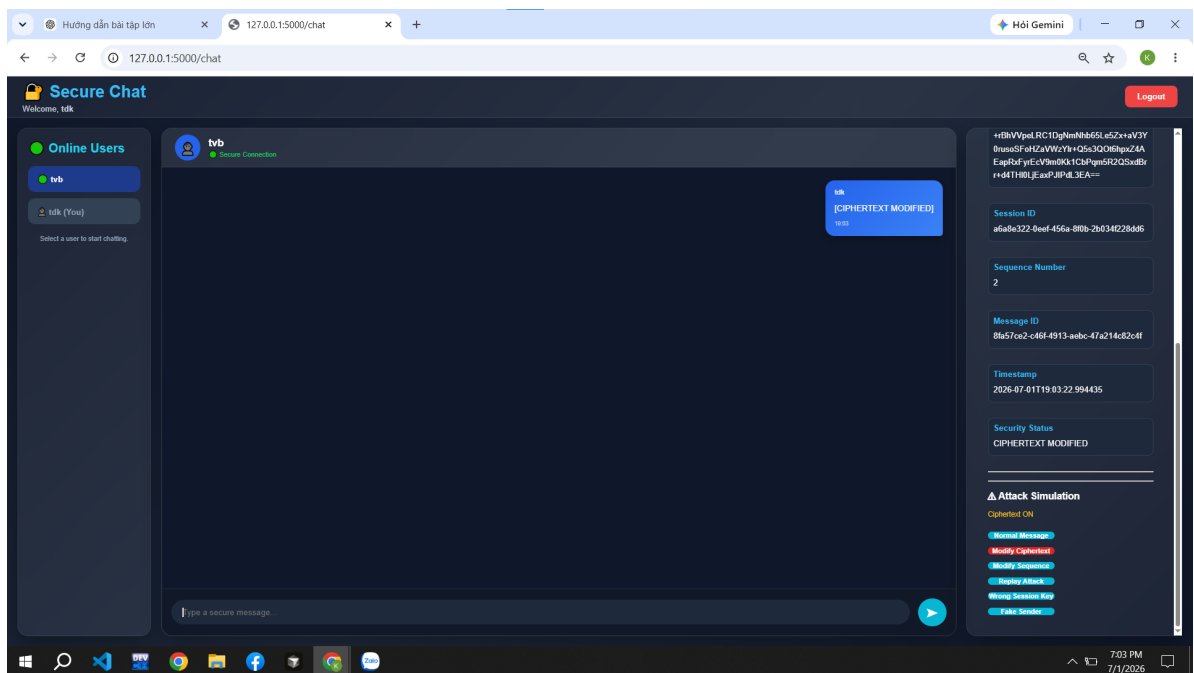
Kết quả cuối cùng là một hệ thống nhắn tin thời gian thực tích hợp nhiều cơ chế bảo mật hiện đại như RSA-OAEP, AES-GCM, RSA-PSS, Replay Detector và Session Key Rotation.

2.2 Các cuộc tấn công được mô phỏng

Để đánh giá hiệu quả của các cơ chế bảo mật đã triển khai, nhóm xây dựng nhiều tình huống tấn công thường gặp trong lĩnh vực An toàn thông tin. Mỗi cuộc tấn công đều được thực hiện trực tiếp trên hệ thống nhằm kiểm tra khả năng phát hiện và xử lý của các cơ chế bảo mật.

2.2.1 Modify Ciphertext

Kẻ tấn công thay đổi nội dung bản mã (Ciphertext) trước khi dữ liệu được gửi đến người nhận. Nhờ cơ chế Authentication Tag của AES-GCM, hệ thống có thể phát hiện dữ liệu đã bị thay đổi và từ chối giải mã.



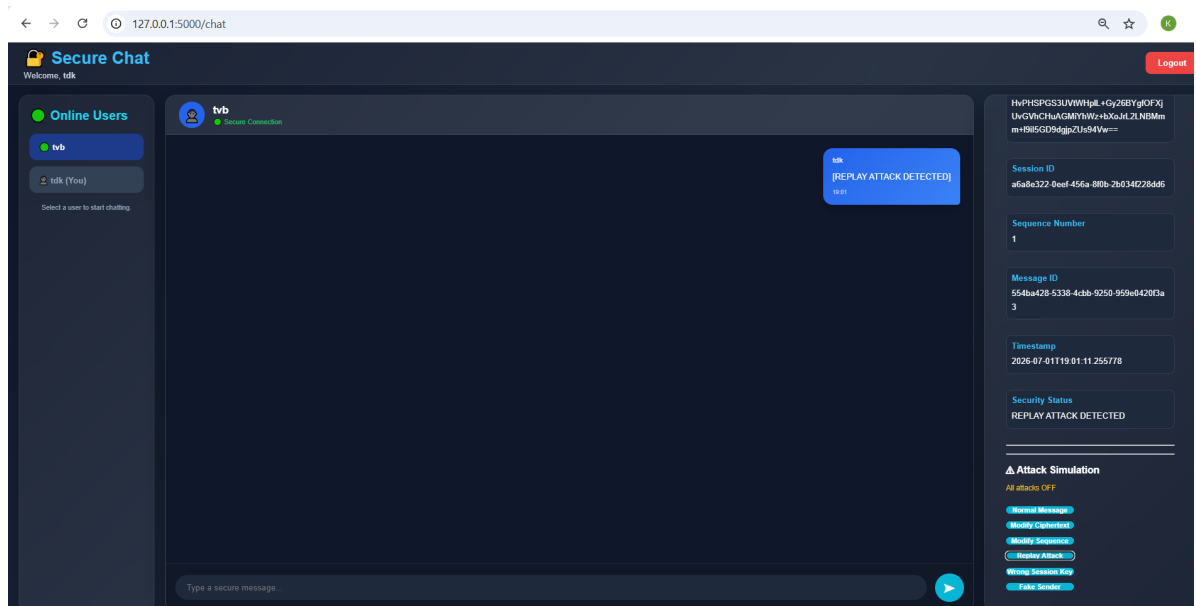
Hình 2.1. Mô phỏng tấn công Modify Ciphertext

Nguồn: Trần Khiêm

2.2.2 Replay Attack

Replay Attack là hình thức gửi lại một gói tin đã được truyền trước đó nhằm đánh lừa hệ thống. Replay Detector sử dụng Message ID để phát hiện các gói tin đã từng được xử lý và

tự động từ chối các gói tin bị phát lại.

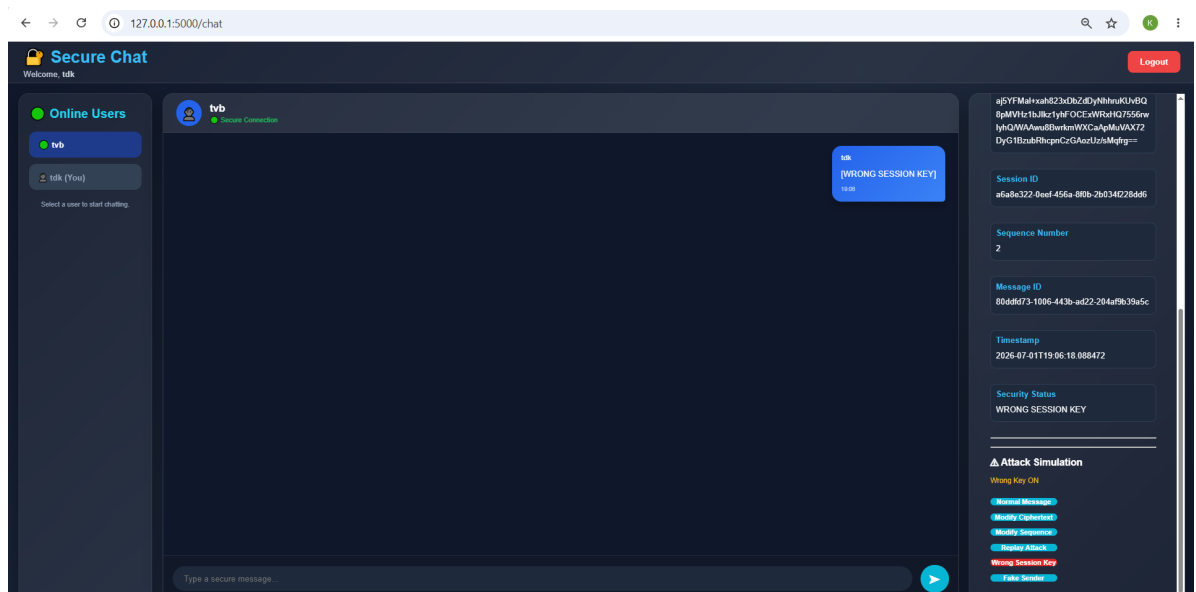


Hình 2.2. Mô phỏng Replay Attack

Nguồn: Trần Khiêm

2.2.3 Wrong Session Key

Trong tình huống này, người nhận sử dụng một Session Key không đúng để giải mã dữ liệu. Do khóa phiên không khớp với khóa dùng để mã hóa nên quá trình giải mã thất bại và hệ thống sinh cảnh báo.

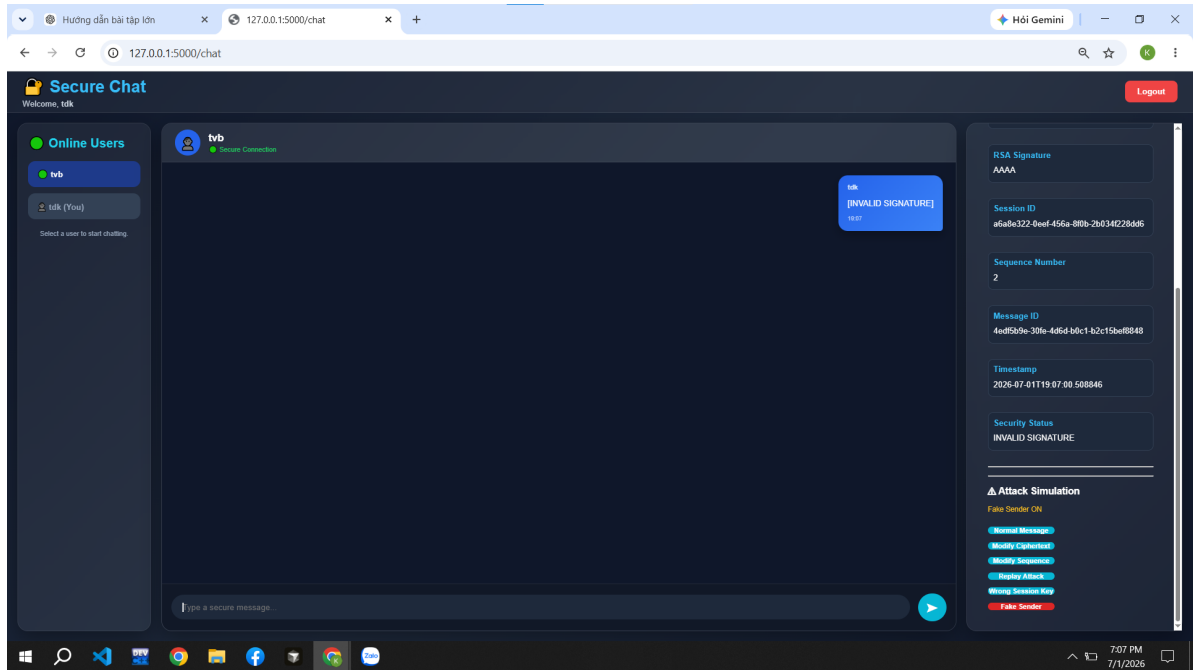


Hình 2.3. Mô phỏng sử dụng Session Key không hợp lệ

Nguồn: Trần Khiêm

2.2.4 Fake Sender

Kẻ tấn công thay đổi thông tin người gửi hoặc cố gắng giả mạo chữ ký số. Nhờ cơ chế xác thực RSA-PSS, hệ thống kiểm tra chữ ký trước khi giải mã và phát hiện ngay hành vi giả mạo.

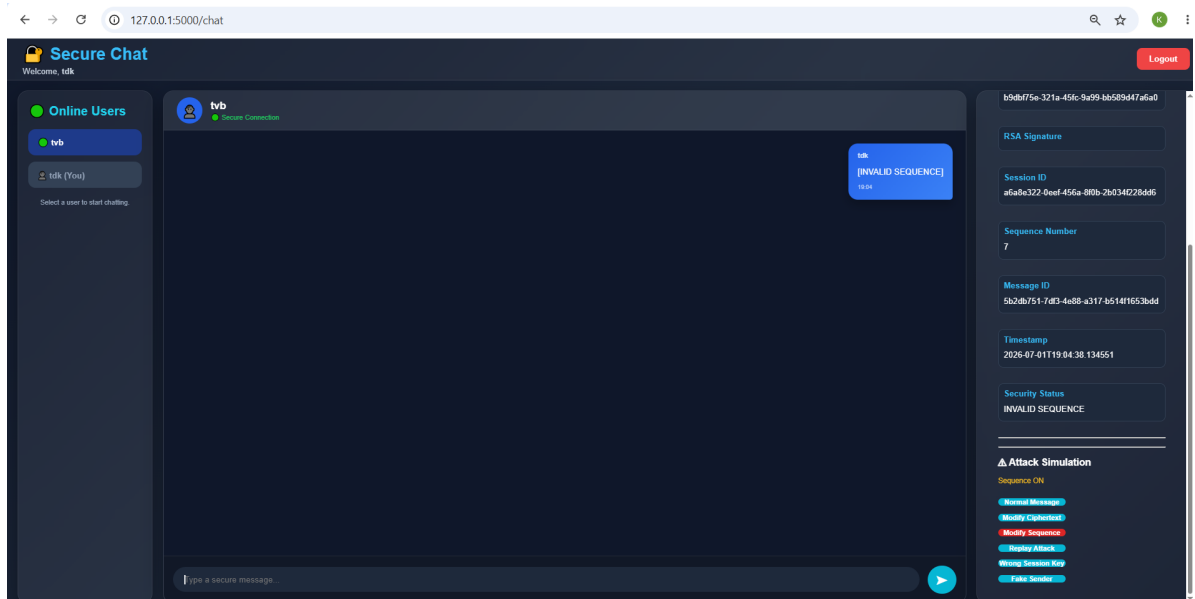


Hình 2.4. Mô phỏng tấn công Fake Sender

Nguồn: Trần Khiêm

2.2.5 Modify Sequence Number

Sequence Number được sử dụng để kiểm tra thứ tự của các gói tin trong một phiên làm việc. Khi số thứ tự bị thay đổi, hệ thống phát hiện sự bất thường và cảnh báo nguy cơ tấn công hoặc dữ liệu bị chỉnh sửa.



Hình 2.5. Mô phỏng tấn công Modify Sequence Number

Nguồn: Trần Khiêm

Sau khi thực hiện các tình huống trên, hệ thống đều đưa ra cảnh báo tương ứng trên bảng Security Information. Điều này chứng minh các cơ chế bảo mật được triển khai có khả năng phát hiện hiệu quả các hành vi tấn công và đảm bảo tính bí mật, toàn vẹn cũng như xác thực của dữ liệu trong quá trình truyền thông.

2.3 Kiến trúc hệ thống và luồng xử lý dữ liệu

Hệ thống được thiết kế theo mô hình Client–Server nhằm tách riêng phần giao diện người dùng và phần xử lý logic bảo mật. Máy chủ chịu trách nhiệm quản lý người dùng, tạo và duy trì phiên làm việc, kiểm tra tính hợp lệ của các gói tin và xử lý các cơ chế bảo mật như xác thực, phát hiện tấn công phát lại và quay vòng khóa. Client thực hiện các thao tác gửi/nhận tin nhắn, hiển thị giao diện và truyền dữ liệu tới server theo thời gian thực.

Luồng thực hiện dữ liệu bắt đầu từ bước đăng nhập, tiếp theo là thiết lập phiên làm việc và trao đổi khóa phiên giữa hai bên. Khi người dùng gửi tin nhắn, nội dung sẽ được mã hóa bằng AES-GCM trước khi truyền đi, đồng thời hệ thống tạo một chữ ký số bằng RSA-PSS để xác thực người gửi. Ở phía nhận, hệ thống kiểm tra chữ ký, kiểm tra thứ tự gói tin và phát hiện các trường hợp phát lại trước khi tiến hành giải mã. Cách tổ chức như vậy giúp hệ thống vừa bảo đảm khả năng giao tiếp thời gian thực vừa tăng cường độ tin cậy của dữ liệu.

2.4 Các công việc đã thực hiện

Trong quá trình xây dựng hệ thống, nhóm đã hoàn thành các nội dung chính sau:

- Phân tích yêu cầu và thiết kế kiến trúc hệ thống.
- Thiết kế giao diện đăng ký, đăng nhập và màn hình nhắn tin.
- Xây dựng chức năng đăng ký và đăng nhập người dùng.
- Xây dựng chức năng nhắn tin thời gian thực bằng Flask-SocketIO.
- Tích hợp RSA-OAEP để trao đổi khóa phiên.
- Tích hợp AES-GCM để mã hóa và giải mã nội dung tin nhắn.
- Tích hợp RSA-PSS để ký số và xác thực người gửi.
- Xây dựng Replay Detector.
- Quản lý Session ID, Message ID và Sequence Number.
- Cài đặt Session Key Rotation.
- Thiết kế bảng Security Information.
- Xây dựng các chức năng mô phỏng tấn công.
- Kiểm thử và đánh giá toàn bộ hệ thống.

2.5 Quy trình phát triển hệ thống

Quá trình phát triển hệ thống được thực hiện theo các bước sau:

1. Khảo sát yêu cầu và xác định mục tiêu của hệ thống.
2. Thiết kế giao diện và kiến trúc tổng thể.
3. Xây dựng các chức năng cơ bản.
4. Tích hợp các thuật toán mật mã.
5. Hoàn thiện cơ chế bảo mật.
6. Kiểm thử và tối ưu hệ thống.

2.6 Chi tiết quá trình thực hiện

Bảng 2.1. Quá trình thực hiện đề tài

Giai đoạn	Thời gian	Nội dung thực hiện	Kết quả đạt được
1	Tuần 1	Khảo sát yêu cầu đề tài, nghiên cứu Flask, Socket.IO và các thuật toán mật mã RSA, AES.	Xây dựng định hướng phát triển hệ thống.
2	Tuần 2	Thiết kế giao diện và kiến trúc hệ thống; xây dựng chức năng đăng ký và đăng nhập.	Hoàn thành giao diện Login và Register.
3	Tuần 3	Xây dựng chức năng nhắn tin thời gian thực; tích hợp RSA-OAEP, AES-GCM và RSA-PSS.	Hoàn thiện chức năng gửi và nhận tin nhắn bảo mật.
4	Tuần 4	Xây dựng Replay Detector, Session Manager, Session Key Rotation và bảng Security Information.	Hoàn thiện các cơ chế bảo mật của hệ thống.
5	Tuần 5	Xây dựng các chức năng mô phỏng tấn công gồm Modify Ciphertext, Replay Attack, Wrong Session Key, Fake Sender và Modify Sequence Number.	Hoàn thành các chức năng kiểm thử an toàn thông tin.
6	Tuần 6	Kiểm thử toàn bộ hệ thống, sửa lỗi và tối ưu chương trình.	Hoàn thiện phiên bản cuối cùng của hệ thống.

Nguồn: Nhóm tác giả tổng hợp

Chương 3

KẾT QUẢ THỰC HIỆN ĐỀ TÀI

3.1 Tóm tắt nội dung đã thực hiện

Sau quá trình nghiên cứu, thiết kế và xây dựng hệ thống, nhóm đã hoàn thành đề tài **Secure Chat System with Cryptographic Security** dưới dạng một ứng dụng Web hỗ trợ nhắn tin thời gian thực kết hợp nhiều cơ chế bảo mật hiện đại.

Trong quá trình thực hiện, nhóm đã hoàn thành các nội dung chính sau:

- Thiết kế giao diện đăng ký, đăng nhập và nhắn tin.
- Xây dựng hệ thống truyền tin thời gian thực bằng Flask-SocketIO.
- Áp dụng RSA-OAEP để trao đổi khóa phiên.
- Áp dụng AES-GCM để mã hóa và giải mã nội dung tin nhắn.
- Áp dụng RSA-PSS để ký số và xác thực người gửi.
- Quản lý Session ID, Message ID và Sequence Number.
- Xây dựng Replay Detector nhằm phát hiện Replay Attack.
- Xây dựng Session Key Rotation nhằm tăng cường bảo mật.
- Thiết kế bảng Security Information hiển thị đầy đủ thông tin bảo mật của từng gói tin.
- Xây dựng các chức năng mô phỏng các cuộc tấn công bảo mật để kiểm thử hệ thống.

Kết quả đạt được đáp ứng đầy đủ các mục tiêu đặt ra ban đầu, đồng thời minh họa trực quan quá trình hoạt động của các cơ chế bảo mật trong một hệ thống truyền thông an toàn.

3.2 Sản phẩm đã xây dựng

Sản phẩm của đề tài là hệ thống:

Secure Chat System with Cryptographic Security

Hệ thống được xây dựng dưới dạng ứng dụng Web cho phép nhiều người dùng trao đổi tin nhắn theo thời gian thực, đồng thời bảo đảm tính bảo mật, tính toàn vẹn và tính xác thực của dữ liệu.

Các chức năng chính của hệ thống gồm:

- Đăng ký tài khoản.
- Đăng nhập người dùng.
- Hiện thị danh sách người dùng trực tuyến.
- Gửi và nhận tin nhắn thời gian thực.
- Trao đổi khóa RSA-OAEP.
- Mã hóa nội dung bằng AES-GCM.
- Ký số RSA-PSS.
- Phát hiện Replay Attack.
- Session Key Rotation.
- Hiện thị Security Information.
- Mô phỏng các cuộc tấn công bảo mật.

Các công nghệ sử dụng được trình bày trong Bảng 3.1.

Bảng 3.1. Danh sách công nghệ sử dụng

STT	Công nghệ/Công cụ	Mục đích sử dụng
1	Python	Ngôn ngữ lập trình chính.
2	Flask	Xây dựng Web Server.
3	Flask-SocketIO	Truyền dữ liệu thời gian thực.
4	HTML/CSS/JavaScript	Thiết kế giao diện Web.
5	RSA-OAEP	Trao đổi khóa phiên.
6	AES-GCM	Mã hóa nội dung tin nhắn.
7	RSA-PSS	Ký số và xác thực người gửi.
8	Git/GitHub	Quản lý mã nguồn.
9	Visual Studio Code	Môi trường phát triển.
10	Cryptography Library	Thực hiện các thuật toán mật mã.

Nguồn: Nhóm tác giả tổng hợp

3.3 Kỹ năng đã rèn luyện được

3.3.1 Kỹ năng chuyên môn

Thông qua quá trình thực hiện đề tài, nhóm đã rèn luyện được các kỹ năng sau:

- Thiết kế hệ thống phần mềm.
- Lập trình Web bằng Flask.
- Lập trình Socket.IO thời gian thực.
- Áp dụng các thuật toán mật mã hiện đại.
- Thiết kế giao diện Web.
- Đọc hiểu tài liệu kỹ thuật tiếng Anh.
- Kiểm thử và tối ưu hệ thống.
- Quản lý mã nguồn bằng Git và GitHub.

3.3.2 Kỹ năng mềm

Ngoài kiến thức chuyên môn, nhóm còn rèn luyện được:

- Làm việc nhóm.
- Quản lý tiến độ dự án.
- Phân chia công việc.
- Giải quyết vấn đề.
- Tự nghiên cứu công nghệ mới.
- Viết tài liệu kỹ thuật.
- Thuyết trình sản phẩm.

3.4 Đề xuất phát triển hệ thống

Trong tương lai, hệ thống có thể tiếp tục phát triển theo các hướng sau:

- Hoàn thiện cơ chế End-to-End Encryption.
- Lưu trữ lịch sử tin nhắn bằng cơ sở dữ liệu.
- Hỗ trợ gửi hình ảnh và tập tin.
- Phát triển phiên bản Mobile.
- Tích hợp xác thực hai lớp (2FA).
- Triển khai trên nền tảng Cloud.
- Xây dựng Dashboard thống kê các sự kiện bảo mật.

3.5 Đánh giá kết quả thực hiện

Đề tài đã hoàn thành đầy đủ các mục tiêu đặt ra. Hệ thống hoạt động ổn định, cho phép truyền tin theo thời gian thực đồng thời áp dụng thành công nhiều cơ chế bảo mật như RSA-OAEP, AES-GCM, RSA-PSS, Replay Detection và Session Key Rotation.

Về mặt chức năng, hệ thống đã đáp ứng được các nhu cầu cơ bản của một ứng dụng nhắn tin bảo mật, bao gồm đăng ký, đăng nhập, trao đổi tin nhắn, quản lý phiên làm việc và hiển thị thông tin bảo mật của từng gói tin. Về mặt bảo mật, các cơ chế phát hiện và ngăn chặn tấn công đã được tích hợp và kiểm thử với nhiều kịch bản khác nhau. Về mặt học thuật, đề tài cũng giúp nhóm củng cố được kiến thức về mật mã học, an toàn thông tin và phát triển hệ thống mạng. Đây là nền tảng tốt để tiếp tục nâng cấp hệ thống trong các nghiên cứu hoặc dự án thực tế tiếp theo.

Ngoài ra, việc xây dựng các chức năng mô phỏng tấn công giúp minh họa rõ khả năng phát hiện và ngăn chặn các hành vi tấn công thường gặp trong truyền thông mạng, góp phần nâng cao giá trị thực tiễn của đề tài.

Thông qua quá trình thực hiện, nhóm đã củng cố kiến thức về An toàn thông tin, Mật mã học, Lập trình Web và quy trình phát triển phần mềm, đồng thời tích lũy được nhiều kinh nghiệm phục vụ cho các nghiên cứu và dự án trong tương lai.

KẾT LUẬN

Sau quá trình nghiên cứu và thực hiện đề tài **Secure Chat System with Cryptographic Security**, nhóm đã hoàn thành việc xây dựng một hệ thống nhắn tin thời gian thực có tích hợp nhiều cơ chế bảo mật hiện đại nhằm đảm bảo tính bảo mật, toàn vẹn và xác thực của dữ liệu trong quá trình truyền thông.

Hệ thống đã triển khai thành công các thuật toán mật mã gồm **RSA-OAEP** để trao đổi khóa phiên, **AES-GCM** để mã hóa và xác thực dữ liệu, cùng với **RSA-PSS** để ký số và xác minh người gửi. Bên cạnh đó, hệ thống còn tích hợp các cơ chế bảo mật như **Replay Detector**, **Sequence Number Validation**, **Session ID**, **Message ID** và **Session Key Rotation**, góp phần nâng cao khả năng phòng chống các hình thức tấn công phổ biến đối với hệ thống nhắn tin.

Thông qua quá trình xây dựng và kiểm thử, hệ thống đã chứng minh khả năng phát hiện và ngăn chặn hiệu quả các kịch bản tấn công như thay đổi nội dung bản mã (Modify Ciphertext), thay đổi số thứ tự gói tin (Modify Sequence Number), phát lại gói tin (Replay Attack), sử dụng khóa phiên không hợp lệ (Wrong Session Key) và giả mạo người gửi (Fake Sender). Các kết quả kiểm thử cho thấy những cơ chế bảo mật được triển khai hoạt động ổn định và đáp ứng đúng mục tiêu đề ra.

Trong quá trình thực hiện đề tài, nhóm đã củng cố được nhiều kiến thức về mật mã học, an toàn thông tin, lập trình ứng dụng Web và phát triển hệ thống theo mô hình Client–Server. Đồng thời, nhóm cũng rèn luyện được kỹ năng nghiên cứu tài liệu, làm việc nhóm, phân tích yêu cầu, thiết kế hệ thống và giải quyết các vấn đề phát sinh trong quá trình phát triển phần mềm.

Mặc dù đã đạt được các mục tiêu chính, hệ thống vẫn còn một số hạn chế như chưa triển khai lưu trữ khóa trên phần cứng chuyên dụng, chưa hỗ trợ xác thực đa yếu tố (Multi-Factor Authentication), chưa tích hợp cơ chế mã hóa đầu cuối (End-to-End Encryption) hoàn chỉnh cho nhiều thiết bị và chưa đánh giá hiệu năng trên quy mô lớn.

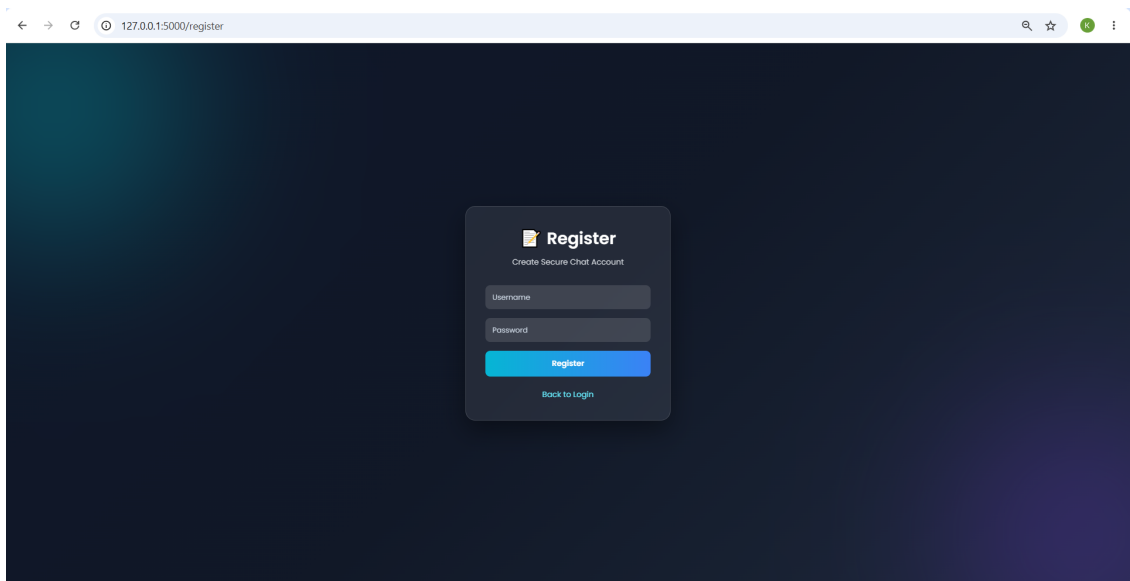
Trong thời gian tới, nhóm dự định tiếp tục phát triển hệ thống theo các hướng như bổ sung xác thực đa yếu tố, triển khai cơ chế End-to-End Encryption hoàn chỉnh, tối ưu hiệu năng khi số lượng người dùng tăng cao, hỗ trợ nhiều nền tảng khác nhau và nghiên cứu tích hợp các thuật toán mật mã hậu lượng tử (Post-Quantum Cryptography) nhằm nâng cao hơn nữa khả năng bảo mật của hệ thống.

PHỤ LỤC

Phụ lục 1. Hình ảnh giao diện hệ thống

Phụ lục này trình bày một số giao diện chính của hệ thống Secure Chat System with Cryptographic Security nhằm minh họa quá trình xây dựng và kết quả đạt được sau khi hoàn thành đề tài.

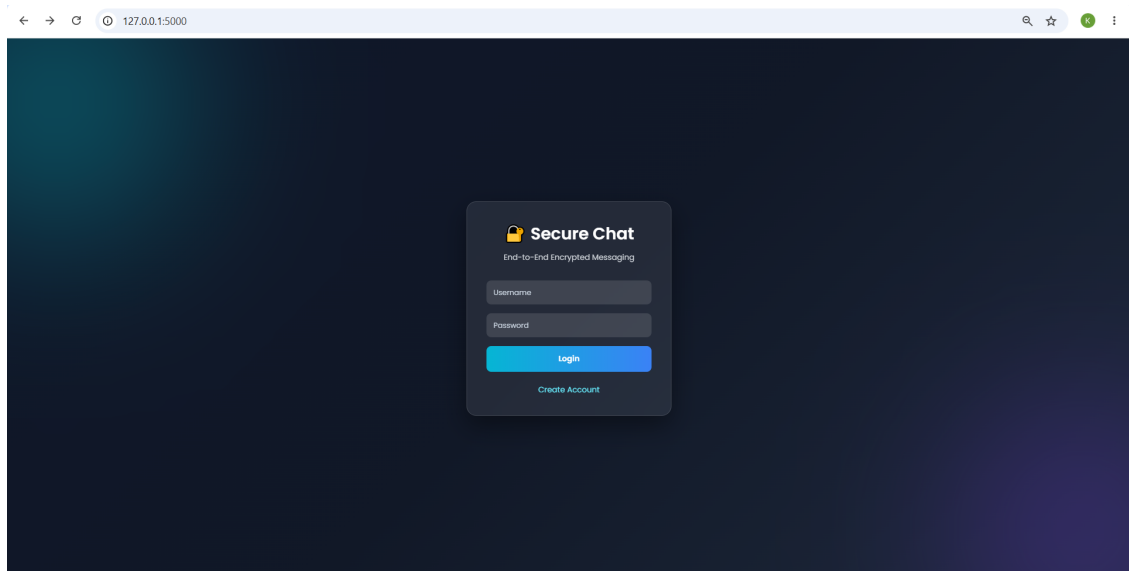
- Giao diện đăng ký tài khoản (Register).



Hình .1. Giao diện đăng ký tài khoản

Nguồn: Trần Khiêm

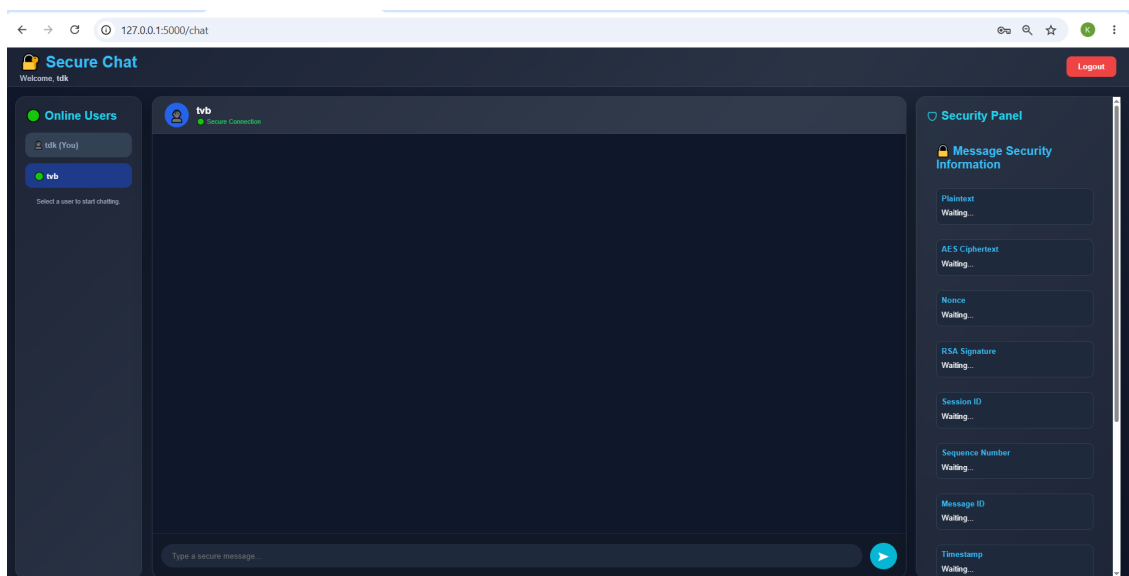
- Giao diện đăng nhập hệ thống (Login).



Hình .2. Giao diện đăng nhập

Nguồn: Trần Khiêm

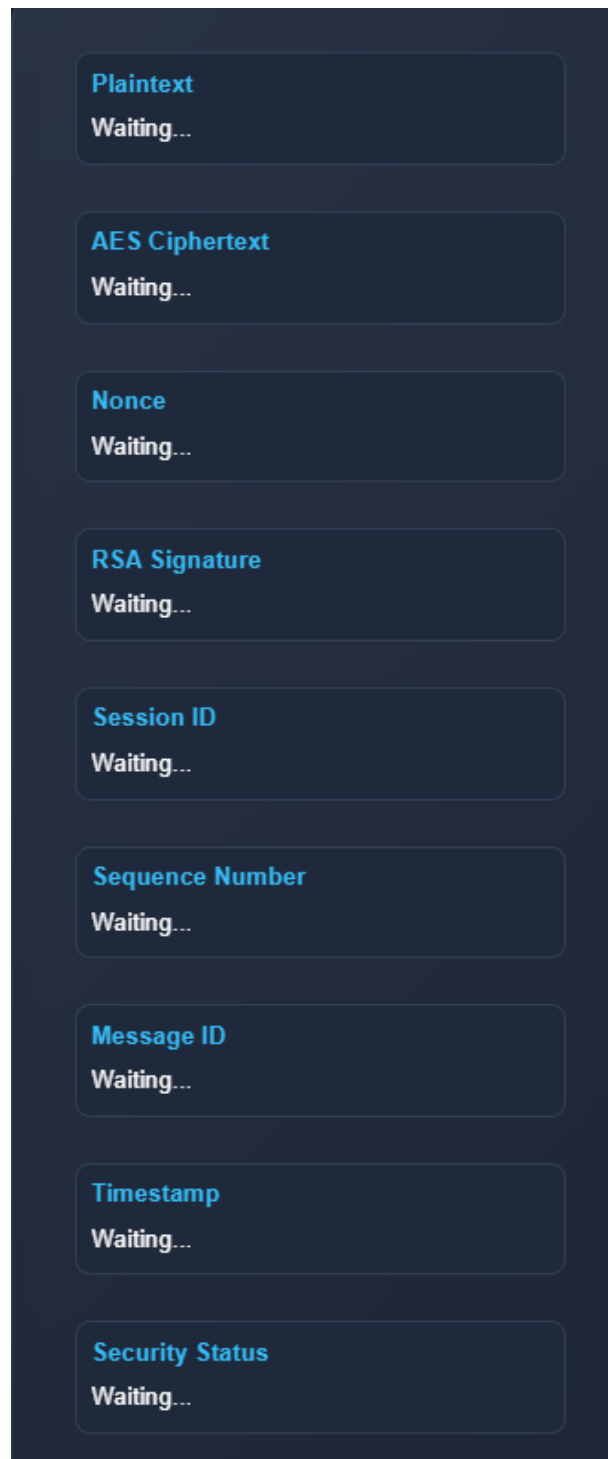
- Giao diện nhắn tin thời gian thực (Chat).



Hình .3. Giao diện nhắn tin thời gian thực

Nguồn: Trần Khiêm

- Giao diện Security Information hiển thị các thông tin bảo mật của từng gói tin.



Plaintext
Waiting...

AES Ciphertext
Waiting...

Nonce
Waiting...

RSA Signature
Waiting...

Session ID
Waiting...

Sequence Number
Waiting...

Message ID
Waiting...

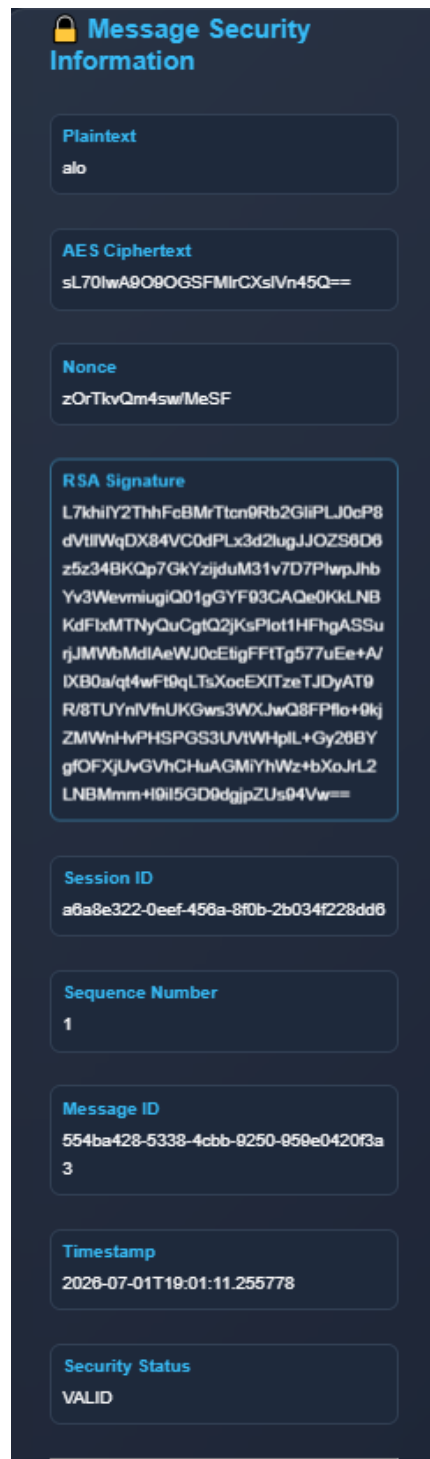
Timestamp
Waiting...

Security Status
Waiting...

Hình .4. Giao diện Security Information

Nguồn: Trần Khiêm

- Giao diện mô phỏng các cuộc tấn công như Modify Ciphertext, Replay Attack, Wrong Session Key, Fake Sender và Modify Sequence Number.



Hình .5. Tiếp tục giao diện Security Information

Nguồn: Trần Khiêm

Phụ lục 2. Cấu trúc dự án

Dự án được tổ chức theo cấu trúc thư mục nhằm thuận tiện cho việc phát triển và bảo trì hệ thống.

- app.py: Chương trình chính khởi động Web Server.

- routes/: Xử lý các yêu cầu HTTP.
- templates/: Chứa các giao diện HTML.
- static/: Chứa CSS, JavaScript và các tài nguyên tĩnh.
- crypto/: Cài đặt các thuật toán RSA-OAEP, AES-GCM và RSA-PSS.
- security/: Xử lý Replay Detector, Session Manager và Session Key Rotation.
- database/: Quản lý dữ liệu người dùng và phiên làm việc.

Phụ lục 3. Môi trường phát triển

Hệ thống được xây dựng và kiểm thử trong môi trường sau:

- Hệ điều hành: Windows 10/11.
- Python 3.12.
- Flask.
- Flask-SocketIO.
- Cryptography Library.
- Visual Studio Code.
- Git và GitHub.

Phụ lục 4. Liên kết dự án

Nếu được phép công bố, có thể bổ sung các liên kết sau:

- Link GitHub của dự án.
- Video demo hệ thống.
- Tài liệu hướng dẫn sử dụng.
- Slide thuyết trình.

DANH MỤC TÀI LIỆU THAM KHẢO

- [1] Thạc sĩ Lê Thị Thuỳ Trang. (2026). *Bài giảng Nhập môn An toàn thông tin*. Trường Đại học Đại Nam.
- [2] Bộ Giáo dục và Đào tạo. (2021). *Giáo trình An toàn và Bảo mật Thông tin*. Nhà xuất bản Giáo dục Việt Nam.
- [3] Nguyễn Bình. (2020). *Mật mã học và An toàn thông tin*. Nhà xuất bản Khoa học và Kỹ thuật.
- [4] Nguyễn Kim Khánh. (2019). *Lập trình Python*. Nhà xuất bản Đại học Quốc gia Hà Nội.
- [5] National Institute of Standards and Technology (NIST). (2023). *Advanced Encryption Standard (AES)*. FIPS Publication 197.
- [6] National Institute of Standards and Technology (NIST). (2023). *Advanced Encryption Standard (AES)*. FIPS Publication 197.
- [7] National Institute of Standards and Technology (NIST). (2007). *Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM)*. NIST Special Publication 800-38D.
- [8] Rivest, R. L., Shamir, A., & Adleman, L. (1978). *A Method for Obtaining Digital Signatures and Public-Key Cryptosystems*. Communications of the ACM, 21(2), 120–126.